CIB-02 · Ciberseguridad e identidad digital

Ley que establece obligaciones de ciberseguridad para los operadores de servicios esenciales e infraestructuras críticas digitales

Define por ley los sectores y criterios para calificar operadores de servicios esenciales y fija obligaciones mínimas de gestión de riesgo cibernético, auditoría y continuidad, articulando el régimen de Activos Críticos Nacionales del Decreto Supremo 106-2017-PCM con la supervisión sectorial.

Comisión (Cámara de Diputados): Defensa Nacional y Orden Interno (+ Ciencia, Innovación Tecnológica y Sociedad Digital) · **Revisora (Senado):** Defensa Nacional y Orden Interno · **Prioridad:** alta · **Costo fiscal:** bajo · **Plazo:** mediano

Plan Perú 2050: Ciber Seguridad, Defensa, Infraestructura y Construcción

I. Exposición de motivos

La protección de infraestructuras críticas en el Perú se rige principalmente por el Decreto Supremo 106-2017-PCM, que regula la identificación y gestión de riesgos de los Activos Críticos Nacionales bajo coordinación de la Dirección Nacional de Inteligencia, con un enfoque de seguridad física y defensa. El Decreto Supremo 126-2025-PCM extiende ciertas obligaciones de confianza digital a sectores listados, pero, según el análisis de Apaxi (2026), fuera de ellos sus reglas son solo referenciales y la designación de un oficial de seguridad es facultativa en el sector privado. La regulación más desarrollada es la del sistema financiero (Resolución SBS 504-2021); otros sectores esenciales como energía, agua y saneamiento, salud o transporte carecen de un estándar legal homogéneo de ciberseguridad. Esto crea asimetrías: un mismo ataque de ransomware puede paralizar un hospital o una empresa de agua sin que exista obligación legal de contar con planes de continuidad probados, auditorías periódicas ni controles mínimos. Experiencias como NIS2 en la Unión Europea o la SOCI Act australiana muestran que un listado legal de sectores con obligaciones proporcionales es la base de la resiliencia nacional.

II. Fórmula legal

EL CONGRESO DE LA REPÚBLICA ha dado la Ley siguiente:

LEY QUE ESTABLECE OBLIGACIONES DE CIBERSEGURIDAD PARA LOS OPERADORES DE SERVICIOS ESENCIALES E INFRAESTRUCTURAS CRÍTICAS DIGITALES

Artículo 1. Objeto

La presente ley tiene por objeto establecer los criterios para calificar a los operadores de servicios esenciales y las obligaciones mínimas de ciberseguridad que les son exigibles, a fin de garantizar la continuidad de los servicios de los que depende la vida, la salud, la seguridad y la actividad económica de la población.

Artículo 2. Sectores esenciales

Son sectores esenciales: energía eléctrica e hidrocarburos; agua potable y saneamiento; salud; transporte; telecomunicaciones e infraestructura digital; sistema financiero, de seguros y de pagos; administración pública digital; y servicios de emergencia. Por decreto supremo con voto aprobatorio del Consejo de Ministros pueden incorporarse otros sectores.

Artículo 3. Calificación de operadores

El organismo regulador o supervisor del sector, o en su defecto el ministerio rector, califica como operador de servicio esencial a la entidad pública o privada cuyo servicio cumpla criterios de número de usuarios, dependencia intersectorial, impacto territorial y ausencia de alternativas inmediatas. La lista de operadores calificados es reservada en su detalle técnico y pública en su número por sector.

Artículo 4. Obligaciones mínimas

Los operadores de servicios esenciales: a) implementan un sistema de gestión de seguridad de la información basado en estándares reconocidos internacionalmente; b) designan un oficial de seguridad y confianza digital con acceso directo a la alta dirección; c) mantienen planes de continuidad y recuperación probados al menos

una vez al año; d) gestionan el riesgo de la cadena de suministro tecnológica; e) notifican incidentes conforme a la ley de la materia; y f) aplican las directivas de mitigación que emita la autoridad nacional de ciberseguridad.

Artículo 5. Responsabilidad de la alta dirección

El directorio o máximo órgano de gobierno del operador aprueba la política de ciberseguridad, asigna los recursos necesarios y recibe, al menos semestralmente, un informe sobre el estado de riesgo cibernético. Sus integrantes deben acreditar capacitación básica en gestión de riesgo cibernético.

Artículo 6. Auditorías

Los operadores se someten a una auditoría de ciberseguridad cada dos años, realizada por auditores acreditados, cuyo informe se remite al supervisor sectorial y a la autoridad nacional de ciberseguridad. El supervisor puede disponer auditorías extraordinarias ante incidentes significativos.

Artículo 7. Articulación con Activos Críticos Nacionales

Los operadores que a su vez administren Activos Críticos Nacionales conforme al Decreto Supremo 106-2017-PCM integran las obligaciones de la presente ley en sus planes de seguridad. La autoridad nacional de ciberseguridad y la Dirección Nacional de Inteligencia establecen un protocolo de intercambio de información reservada.

Artículo 8. Supervisión y sanción

La supervisión corresponde al organismo regulador o supervisor sectorial con competencia sobre el operador, conforme a su ley de creación y tipificación. En los sectores sin supervisor, la ejerce la autoridad nacional de ciberseguridad.

Artículo 9. Proporcionalidad

El reglamento establece un régimen simplificado para operadores de menor tamaño y gobiernos locales, que conserva las obligaciones de los literales b), c) y e) del artículo 4.

Primera. Disposición Complementaria Final

Reglamentación. El Poder Ejecutivo, mediante decreto supremo refrendado por el Presidente del Consejo de Ministros y los ministros de los sectores comprendidos, reglamenta la presente ley en un plazo no mayor de 120 días hábiles contados desde su entrada en vigencia.

Segunda. Disposición Complementaria Final

Plazo de adecuación. Los operadores calificados cuentan con 18 meses desde su notificación para cumplir las obligaciones del artículo 4 y con 30 meses para la primera auditoría.

Tercera. Disposición Complementaria Final

Régimen financiero existente. Las empresas supervisadas por la Superintendencia de Banca, Seguros y AFP que cumplan la Resolución SBS 504-2021 o la que la sustituya se consideran conformes con el artículo 4, sin perjuicio de las auditorías del artículo 6.

III. Análisis costo-beneficio

El costo recae principalmente en los operadores privados y públicos calificados (sistemas de gestión, auditorías bienales, personal especializado); para el Estado, el gasto es bajo porque la supervisión se encarga a reguladores ya existentes con sus propios recursos. El beneficio es la reducción de la probabilidad y del impacto de interrupciones en servicios vitales, cuyos costos sociales (atención de salud, agua, energía, pagos) superan con amplitud el gasto preventivo, aunque en el Perú no existe una cuantificación oficial. El régimen simplificado y el reconocimiento del cumplimiento SBS evitan duplicidad. No demanda recursos adicionales al Tesoro Público.

IV. Efecto de la vigencia de la norma

Complementa el Decreto de Urgencia 007-2020, su reglamento (Decreto Supremo 126-2025-PCM) y el Decreto Supremo 106-2017-PCM; no modifica la Ley 30999.

V. Indicador de éxito al 2031

A 2031, 100 % de los operadores calificados con auditoría bienal presentada y plan de continuidad probado; número de operadores por sector publicado anualmente.

Normas relacionadas

• Decreto Supremo 106-2017-PCM, Reglamento para la Identificación, Evaluación y Gestión de Riesgos de los Activos Críticos Nacionales — https://www.gob.pe/institucion/pcm/normas-legales/454348-106-2017-pcm

• Decreto de Urgencia 007-2020, que aprueba el Marco de Confianza Digital y dispone medidas para su fortalecimiento — https://www.gob.pe/institucion/pcm/normas-legales/395322-007-2020

• Decreto Supremo 126-2025-PCM, Reglamento del Decreto de Urgencia 007-2020 (Marco de Confianza Digital) — https://busquedas.elperuano.pe/dispositivo/EX/2455024-1

• Resolución SBS 504-2021, Reglamento para la Gestión de la Seguridad de la Información y la Ciberseguridad — https://busquedas.elperuano.pe/dispositivo/NL/1929393-1

• Ley 30999, Ley de Ciberdefensa (2019) — https://busquedas.elperuano.pe/normaslegales/ley-de-ciberdefensa-ley-n-30999-1801519-5/

Antecedentes

Por verificar en SPLEY.

Referencias internacionales

• Unión Europea: Directiva (UE) 2022/2555 (NIS2), medidas para un elevado nivel común de ciberseguridad — https://eur-lex.europa.eu/eli/dir/2022/2555/oj

• Australia: Security of Critical Infrastructure Act 2018 — https://www.legislation.gov.au/C2018A00029/latest/text

• Chile: Ley 21.663, Ley Marco de Ciberseguridad (crea la Agencia Nacional de Ciberseguridad y CSIRT) — https://www.bcn.cl/leychile/navegar?idNorma=1202434

• España: Real Decreto-ley 12/2018, de seguridad de las redes y sistemas de información — https://www.boe.es/buscar/act.php?id=BOE-A-2018-12257

Fuentes

• Apaxi (07-09-2026): Normas de ciberseguridad para empresas en el Perú — https://apaxi.info/2026/09/07/normas-ciberseguridad-empresas-peru/

• gob.pe (DINI): Activos Críticos Nacionales (ACN) — https://www.gob.pe/10400-activos-criticos-nacionales-acn

• EY Perú: Reglamento del Marco de Confianza Digital (DS 126-2025-PCM) — https://www.ey.com/es_pe/technical/tax-alert/reglamento-ley-marco-confianza-digital-medidas-fortalecimiento

• Texto del DS 126-2025-PCM (copia LP Derecho) — https://img.lpderecho.pe/wp-content/uploads/2025/11/Decreto-Supremo-126-2025-PCM-LPDerecho.pdf

Propuesta ciudadana de libre uso — no es un proyecto presentado. Versión web: https://unimauro.github.io/agenda-legislativa-tech/p/CIB-02.html